MODULE 27 · DOMAIN 4 - SECURITY AND COMPLIANCE

Compliance and Detection

Config and conformance packs, GuardDuty, Inspector, Macie, Security Hub and Trusted Advisor.

DOMAIN 4 of 5 EXAM WEIGHT 16% MODULE 27 of 35

admin@sthithapragna.com

Each detective service answers **one** question. They all emit findings in **one format**, so a single rule can automate a response to any of them.

Which service answers which question

QUESTION	SERVICE
Is this resource configured the way we require?	AWS Config
Is something behaving maliciously right now?	Amazon GuardDuty
Does this software have known vulnerabilities?	Amazon Inspector
Is there sensitive data in this bucket?	Amazon Macie
How do we stand against a security standard overall?	Security Hub CSPM
Are we wasting money or approaching a limit?	AWS Trusted Advisor

ON THE EXAM

Read the question a scenario is really asking. Configuration, behaviour, vulnerability, data content, posture, or waste. Six questions, six services.

AWS Config: the recorder

- The **configuration recorder** captures a **configuration item** every time a supported resource changes, plus relationships between resources.
- That builds a **configuration history**, which answers "what did this security group look like last Tuesday?"
- **One recorder per account per Region**, and nothing is recorded until it is switched on. Config is not retrospective.
- A **delivery channel** writes configuration snapshots and history to S3, and can notify an SNS topic.

> ON THE EXAM
>
> Module 5's triangle again: CloudTrail records the API call, Config records the resulting state. Both are needed to answer "who changed it, and to what?"

Config rules

- **AWS managed rules** cover hundreds of common checks and need no code. Start here.
- **Custom rules** are a Lambda function, or a **Guard** policy written in AWS's policy-as-code language.
- Rules are **change-triggered**, **periodic**, or both. Change-triggered evaluates when the resource changes; periodic on a schedule.
- **Remediation** attaches an SSM Automation runbook, automatic or manual, as module 8 covered.

> ON THE EXAM
>
> Config evaluates state, so it finds resources that were already wrong before the rule existed. That is what an event-based control cannot do.

Conformance packs

- A **collection of Config rules and remediation actions**, packaged as a single deployable unit. Added to the exam guide in v1.1.
- AWS publishes **sample packs** for CIS, PCI DSS, HIPAA, NIST 800-53 and others, so a standard is one deployment rather than fifty rules.
- Deploy to **an account and Region, or across an entire organisation** from a delegated administrator.
- The pack is **immutable as a unit**. You change the template and redeploy, rather than editing rules individually.

> ON THE EXAM
>
> "Demonstrate compliance with a named standard across every account" is a conformance pack deployed organisation-wide. Not fifty individually managed rules.

Config at organisation scale

- An **aggregator** collects configuration and compliance data from many accounts and Regions into one view.
- **Advanced queries** run SQL over that aggregated state: every unencrypted volume across the organisation, in one query.
- **Cost is per configuration item recorded and per rule evaluation.** Recording every resource type in every Region adds up quickly.
- The **recording strategy** lets you record all types, all types except an exclusion list, or only specific types.

> ON THE EXAM
>
> Config cost is the one most teams meet by surprise. Noisy resource types with frequent changes generate configuration items continuously.

Amazon GuardDuty

- Analyses **CloudTrail management events, VPC Flow Logs and Route 53 DNS query logs** as foundational data sources.
- **You do not need to enable or pay for those logs.** GuardDuty consumes them independently of anything you have configured.
- **Protection plans** are separate and separately charged: S3, EKS, Malware, RDS, Lambda and Runtime Monitoring.
- Findings carry a severity and an affected resource, and flow to **EventBridge and Security Hub** automatically.

> ON THE EXAM
>
> GuardDuty reads flow logs even if you have never enabled VPC Flow Logs. That independence surprises people and it appears in questions.

GuardDuty Extended Threat Detection

- Generally available **December 2024**. Correlates signals over time into a single **attack sequence** finding.
- Example: credential compromise followed by reconnaissance followed by data exfiltration, presented as **one critical-severity finding** rather than a dozen.
- Attack sequences carry **MITRE ATT&CK tactics and techniques** as indicators.
- **May 2026** added indicators sourced from other services: misconfiguration, reachability, sensitive data and vulnerability context.

> ON THE EXAM
>
> This is why enabling Inspector, Macie and Config improves GuardDuty. The exposure context comes from those services, not from GuardDuty itself.

Amazon Inspector

- Continuously scans **EC2 instances, ECR container images, Lambda functions and Lambda code** for known vulnerabilities.
- **Scans on deploy and rescans automatically when a new CVE is published**, so a clean result does not go stale.
- Produces a **risk score** combining CVE severity with network reachability and exploitability, so findings are prioritised rather than listed.
- **Inspector Classic reached end of support on 20 May 2026.** The modern Inspector is agentless via SSM where possible.

> ON THE EXAM
>
> Rescanning on new CVE publication is the differentiator. A point-in-time scan tells you an image was clean when you built it, not that it is clean now.

Inspector or GuardDuty?

INSPECTOR

What could be exploited

- Known CVEs in software and dependencies
- Network reachability of a vulnerable port
- Proactive: finds weaknesses before anyone uses them
- Scans artefacts and instances

GUARDDUTY

What is being exploited

- Anomalous API calls, credential misuse, C2 traffic
- Cryptomining, data exfiltration patterns
- Reactive: something is happening now
- Analyses logs and runtime behaviour

THE TIEBREAKER

Vulnerability versus activity. Inspector says you have an unlocked door; GuardDuty says somebody just walked through one.

Amazon Macie

- Discovers and classifies **sensitive data inside S3 objects**: personal data, financial data, credentials, health information.
- **Managed data identifiers** cover common types out of the box. **Custom identifiers** use your own patterns and keywords.
- **Automated sensitive data discovery** samples buckets continuously and builds a picture without you defining jobs.
- Also reports the **bucket inventory**: which buckets are public, unencrypted, or shared outside the account.

> ON THE EXAM
>
> Macie reads the contents of objects. That is what separates it from every other service here, and it is what makes it charged by data volume.

Macie or GuardDuty S3 Protection?

MACIE

What is in the objects

- Sensitive data classification
- Managed and custom data identifiers
- Answers: do we hold customer PII here?
- Charged by data volume inspected

GUARDDUTY S3 PROTECTION

How the objects are accessed

- Anomalous access patterns and API calls
- Access from unusual locations or principals
- Answers: is somebody exfiltrating this?
- Charged by S3 data event volume

THE TIEBREAKER

Macie inspects the contents; GuardDuty watches the behaviour. A question about classification is Macie; a question about unusual access is GuardDuty.

Security Hub, and Security Hub CSPM

- **What used to be called Security Hub is now Security Hub CSPM:** standards, controls, a security score, and finding aggregation.
- **Security Hub** is now the broader product that correlates signals across Inspector, GuardDuty, Macie and CSPM.
- **Enabling Security Hub automatically enables Security Hub CSPM.** Inspector and GuardDuty analytics need enabling separately, and **Macie is not enabled automatically**.
- **Security Hub CSPM controls depend on AWS Config being enabled** in each account and Region. Without Config, controls cannot evaluate.

> ON THE EXAM
>
> That last point is a real dependency chain, and it is per account and per Region. A CSPM security score means nothing where Config is switched off.

One finding format, one automation

- Findings from GuardDuty, Inspector, Macie, Config, IAM Access Analyzer and partners are normalised into the **AWS Security Finding Format**.
- That means **one EventBridge rule** can match findings from any source and route them to a runbook, a queue or a ticket.
- **Automation rules** in Security Hub can suppress, change severity or update findings automatically as they arrive.
- **CSPM findings are retained for 90 days** after their last update. Longer retention means exporting them.

> ON THE EXAM
>
> Normalisation is the point of an aggregation layer. Without it you would need a different integration for every detective service you run.

AWS Trusted Advisor

- Five categories: **cost optimisation, performance, security, fault tolerance and service quotas**.
- **A limited set of core checks is available to everyone.** The full set requires a **Business, Enterprise On-Ramp or Enterprise** Support plan.
- **Service quota checks** warn as you approach limits, which module 17 showed is what fails a disaster recovery test.
- Checks can be viewed organisation-wide, and findings can be sent to **EventBridge** for automation.

> ON THE EXAM
>
> Trusted Advisor is the only service here that covers cost and performance as well as security. If a question mentions waste or idle resources, that is the signal.

AWS Security Agent

- Added to skill 4.2.5 in **exam guide v1.1**. Generally available **31 March 2026** for on-demand penetration testing.
- Performs **agentic penetration testing**, plus **STRIDE threat modelling** and repository and pull request scanning.
- Integrates with GitHub, GitLab, Bitbucket and Confluence, so findings arrive where the code review happens.
- **Rename in flight:** announced June 2026 as becoming **Continuum pen testing** and **Continuum code scanning**.

> ON THE EXAM
>
> Answer with the exam guide's name, AWS Security Agent, and recognise Continuum in the console. Module 33 covers the full list of renames in flight.

> A security team enables Security Hub across 40 accounts and adopts the AWS Foundational Security Best Practices standard. In twelve accounts the security score shows as unavailable and most controls report no data, although Security Hub itself is clearly enabled there.
>
> The twelve accounts were created recently by a different team.

What is the most likely cause?

A AWS Config is not enabled in those accounts and Regions, so CSPM controls cannot evaluate

B GuardDuty must be enabled before Security Hub can produce a score

C The accounts need to be invited to the Security Hub delegated administrator

D Amazon Macie is not enabled in those accounts

◆ PAUSE AND DECIDE

What is the most likely cause?

A Config is not enabled

Security Hub CSPM controls evaluate using AWS Config. Without a configuration recorder in that account and Region, controls have nothing to assess.

B GuardDuty required first

GuardDuty enriches Security Hub with threat findings. It has no bearing on whether CSPM controls can evaluate configuration.

C Invite to delegated administrator

Would prevent findings appearing centrally. The scenario says Security Hub is enabled and the controls themselves report no data.

D Macie not enabled

Macie is never enabled automatically, and it classifies data. It contributes nothing to a standard's control evaluations.

THE SIGNAL

The dependency chain is per account and per Region. New accounts often have Security Hub switched on centrally and Config never switched on at all.

> An auditor requires evidence that the company complies with the CIS AWS Foundations Benchmark across all 40 accounts, with automatic remediation where possible, and a single report of which resources are non-compliant.
>
> The team does not want to create and maintain the individual rules by hand.

What should the team implement?

A. A Config conformance pack based on the CIS sample template, deployed organisation-wide, with a Config aggregator for reporting

B. Individual Config rules created by a StackSet in every account

C. GuardDuty enabled organisation-wide

D. Trusted Advisor security checks across the organisation

◆ PAUSE AND DECIDE

What should the team implement?

A CIS conformance pack plus aggregator

A sample pack is the standard as one deployable unit, remediation is included, and the aggregator gives the single cross-account report.

B Individual rules via StackSet

Achieves the same outcome and is exactly the hand-maintained rule set the requirement rules out. Conformance packs exist to replace this.

C GuardDuty

Detects malicious behaviour. It evaluates no configuration and maps to no compliance standard.

D Trusted Advisor

A useful fixed set of checks. It does not implement a named benchmark or provide per-resource compliance evidence.

THE SIGNAL

"A named standard, across every account, without maintaining rules by hand" is precisely what conformance packs were built for, and why v1.1 added them.

> A team receives an alert that an EC2 instance is communicating with a known command-and-control server, and separately that credentials from that instance were used to enumerate S3 buckets and then download a large volume of objects.
>
> They want these related events presented as a single prioritised incident rather than as separate findings.

What provides this?

A GuardDuty Extended Threat Detection, which correlates signals into attack sequence findings

B Amazon Inspector, which correlates vulnerabilities across resources

C A Config conformance pack

D CloudWatch composite alarms across the GuardDuty findings

◆ PAUSE AND DECIDE

What provides this?

A Extended Threat Detection

Built exactly for this: correlating signals across services and time into one critical-severity attack sequence, with MITRE tactics attached.

B Inspector

Finds vulnerabilities in software. It observes no behaviour and correlates no activity.

C Conformance pack

Evaluates configuration against rules. Nothing here is a configuration problem.

D Composite alarms

The thoughtful wrong answer. It groups alarms you already defined, so it cannot discover a relationship you did not anticipate.

THE SIGNAL

Option D is worth a moment: composite alarms combine known signals, while attack sequences discover relationships across services you never linked.

> A company must determine whether any of its 900 S3 buckets contain customer personal data. Separately, it must be alerted if anyone downloads unusual volumes of data from those buckets.
>
> The team has GuardDuty enabled but no other security services.

What should they add?

A Amazon Macie for classification, and GuardDuty S3 Protection for access anomalies

B Amazon Macie alone, which covers both requirements

C GuardDuty S3 Protection alone, which covers both requirements

D Amazon Inspector to scan the buckets

◆ PAUSE AND DECIDE

What should they add?

A Macie plus S3 Protection

Two distinct questions: what is in the objects, and how they are accessed. Neither service answers both.

B Macie alone

Classifies contents and reports bucket posture. It does not monitor access patterns or detect anomalous downloads.

C S3 Protection alone

Detects the unusual download. It has no idea whether the objects contain personal data, because it never reads them.

D Inspector

Scans compute for software vulnerabilities. It does not inspect S3 object contents at all.

THE SIGNAL

Contents versus behaviour, stated as two requirements in one scenario. Options B and C each answer exactly one half, which is what makes them tempting.

> A container image passed its vulnerability scan when it was pushed to ECR three months ago and has been running in production since. A critical CVE affecting one of its base packages was published last week.
>
> The team wants to be told automatically when this happens, without rescanning manually.

What should the team use?

A Amazon Inspector, which rescans automatically when new CVEs are published

B ECR basic scanning on push

C A Config rule checking image age

D GuardDuty Runtime Monitoring on the cluster

◆ PAUSE AND DECIDE

What should the team use?

A Inspector, continuous rescanning

Enhanced scanning re-evaluates existing images whenever a new CVE is published, so an image clean three months ago is reassessed today.

B Basic scanning on push

The exact failure described. It produced a clean result three months ago and that result never changes.

C Config rule on image age

Flags old images regardless of whether they are vulnerable, and stays silent about a new CVE in a recent one.

D Runtime Monitoring

Detects malicious behaviour in running containers. It says nothing about whether the software has a known vulnerability.

THE SIGNAL

Module 21's tiebreaker made concrete: basic scanning is a moment, enhanced scanning is continuous. The three-month gap is the entire question.

The five things to carry forward

- **Configuration, behaviour, vulnerability, data content, posture, waste.** Six questions, six services.
- **Security Hub CSPM controls require AWS Config**, per account and per Region. No Config, no security score.
- **Conformance packs turn a named standard into one deployment**, with remediation, organisation-wide.
- **GuardDuty reads CloudTrail, flow logs and DNS logs independently**, whether or not you have enabled them.
- **Macie reads contents; GuardDuty watches behaviour.** Inspector finds the unlocked door; GuardDuty sees someone walk through it.

> ON THE EXAM
>
> That completes domain four. Next: VPC fundamentals, and the start of domain five.